

# US Patent & Trademark Office

## Patent Public Search | Text View

---

United States Patent Application Publication

20250278493

Kind Code

A1

Publication Date

September 04, 2025

Inventor(s)

Poulin; Christopher et al.

---

### SYSTEMS AND METHODS FOR ACCELERATING CYBERSECURITY ASSESSMENTS

---

#### Abstract

The disclosure relates to a method of selecting a cybersecurity action plan; sending one or more questions; receiving a response to each of the one or more questions; for each question mapped to at least one risk vector rating; determining a risk score based on a weighted combination of the at least one risk vector rating and at least one weight; determining an indication of whether the question is indicative of a cybersecurity risk; and if the risk score is less than or equal to the threshold, assigning a flag to the question to indicate the question is indicative of a cybersecurity risk; and displaying an assessment report configured to show an assessment of cybersecurity risk of the affiliate.

---

**Inventors:** Poulin; Christopher (Walpole, MA), Venugopal; Shyam (Boston, MA), Jankowski; Vanessa (Watkins Glen, NY), Amorin; Kevin (Acton, MA), Bumpus; Hanan (North Grafton, MA), Ye; Zhichun (Sudbury, MA)

**Applicant:** BitSight Technologies, Inc. (Boston, MA)

**Family ID:** 84786300

**Appl. No.:** 19/211601

**Filed:** May 19, 2025

#### Related U.S. Application Data

parent US continuation 17856217 20220701 parent-grant-document US 12353563 child US 19211601

us-provisional-application US 63217617 20210701

---

#### Publication Classification

**Int. Cl.:** G06F21/57 (20130101)

## Background/Summary

CROSS-REFERENCE TO RELATED APPLICATION(S) [0001] This application is a continuation of U.S. application Ser. No. 17/856,217, filed on Jul. 1, 2022, which claims the benefit of and priority to U.S. Provisional Application No. 63/217,617, filed on Jul. 1, 2021, entitled “SYSTEMS AND METHODS FOR ACCELERATING CYBERSECURITY ASSESSMENTS,” which are hereby incorporated by reference in their entireties.

### TECHNICAL FIELD

[0002] The following disclosure is directed to methods and systems for cybersecurity risk mitigation and/or management, more specifically, methods and systems for accelerating an entity's protocols for monitoring and managing cybersecurity risks to determine and validate levels of assessment for affiliates having relationships with the entity.

### BACKGROUND

[0003] Businesses, corporations, organizations, and other ‘entities’ often outsource tasks to third parties. As a result, such entities have relationships with (e.g., are ‘related to’ or ‘connected to’) numerous third party affiliates (i.e., vendors). These relationships can leave entities vulnerable to risks (e.g., threats) arising from the security practices of these third party affiliates. Accordingly, entities may wish to identify third party affiliates requiring additional risk assessment and customize levels of risk assessment based on the cyber security states of the identified third party affiliates.

### SUMMARY

[0004] Reliably monitoring dozens, hundreds, or even thousands of third party affiliates can consume a large amount of an entity's time and other resources. For entities with a large number of third party affiliates, assessing and monitoring each and every affiliate-especially to the same level of detail-can be prohibitively difficult, expensive, and/or time-consuming. Thus, an entity may wish to allocate risk assessment resources to affiliates based on their criticality to the entity and their associated cybersecurity risk. However, an entity may face difficulty in efficiently prioritizing affiliates for risk assessment (e.g., based on having a large quantity of third part affiliates), as well as in determining appropriate levels of assessment based on the criticality of affiliates to the entity. When an entity chooses an unsuitable risk management protocol for a given affiliate, resources may be wasted (e.g., if the risks associated with the affiliate are small but the risk management protocol selected by the entity for the affiliate uses significant resources) or significant risks may be ignored (e.g., if the risks associated with the affiliate are great but the risk management protocol selected by the entity for the affiliate uses insufficient resources). Further, when a risk management protocol is implemented, an entity may lack techniques to validate completed risk assessments, allowing affiliates to mischaracterize and inaccurately portray their associated cybersecurity states. Such deficiencies can negatively impact the efficacy an entity's risk management and mitigation protocols by allowing cybersecurity risks and threats to go unnoticed.

[0005] Thus, there exists a current need for a cybersecurity risk management technique and supporting systems for (1) tiering (i.e., ranking) an entity's affiliates for risk assessment (2) determining a level (i.e., protocol) of risk assessment for each affiliate that optimizes the allocation of security assessment resources of an entity, and (3) validating responses corresponding to the risk assessment from the assessed affiliates. In some embodiments, an entity's affiliates may be tiered based on their criticality to the entity and/or their cyber security risk. Such tiering may be used in

combination with one or more security characteristics (e.g., a security rating, security procedure, security control, etc.) to automatically determine a level of risk assessment to perform for a particular affiliate, where the risk assessment may include a plurality of questions as part of a questionnaire. In some embodiments, one or more risk vectors may be mapped to each of the responses corresponding to the questions of the questionnaire, such that the risk vector(s) indicate a state of each response to a question. An assessment report may be generated based on the responses to the questionnaire, where the assessment report may include an indication of flagged responses corresponding to security attributes and/or areas that require further review, improvement, and/or remediation. Responses may be automatically flagged based on a weighted combination of the risk vectors corresponding to each response, such that an entity may automatically identify cyber security risks corresponding to an affiliate and determine the validity of an affiliate's responses. In one aspect, the disclosure features a computer-implemented method including selecting, for an affiliate of a plurality of affiliates of an entity, a cybersecurity action plan, wherein the selection is based on a combination of a cybersecurity criticality tier, one or more risk vector ratings, and a security rating for the affiliate, wherein each risk vector rating is indicative of a state of a cybersecurity characteristic of the affiliate, wherein the cybersecurity criticality tier is selected from a set of cybersecurity criticality tiers. The method also includes sending, to the affiliate, one or more questions, wherein each question is indicative of a cybersecurity risk of the affiliate, wherein at least one question of the one or more questions is mapped to at least one risk vector and at least one risk vector rating of the one or more risk vector ratings. The method also includes receiving, from the affiliate, a response to each of the one or more questions. The method also includes, for each question mapped to at least one risk vector rating, determining a risk score based on a weighted combination of the at least one risk vector rating and at least one weight; determining, based on a comparison of the risk score to a threshold, an indication of whether the question is indicative of a cybersecurity risk; and if the risk score is less than or equal to the threshold, assigning a flag to the question to indicate the question is indicative of a cybersecurity risk. The method also includes displaying an assessment report configured to show an assessment of cybersecurity risk of the affiliate, wherein the assessment report comprises the one or more questions, the response to each of the one or more questions, the at least one risk vector rating for each question mapped to the at least one risk vector, and the flag for each question that is assigned the flag. Other aspects of the invention comprise systems implemented in various combinations of computing hardware and software to achieve the methods described herein.

[0006] In some embodiments, the risk vector may include at least one of an amount of capital investment; a measure of employee training; an amount of the entity's budget for security; a number of spam propagation instances originating from a computer network associated with the entity; a number of malware servers associated with the entity; a number of potentially exploited devices associated with the entity; and a number of hosts authorized to send emails on behalf of each domain associated with the entity. The risk vector rating may be a numerical rating. Each of the risk vectors may correspond to one of a plurality of risk vector types. The plurality of risk vector types may include data breaches, open ports, botnet infections, potentially exploited device, file sharing, and other risk vector type. Each of the plurality of risk vector types may correspond to one of a plurality of weight, the plurality of weight being numerical. The risk score may be calculated by dividing a sum of a multiplication of each of the risk vector rating and a corresponding weight by a sum of a total weight. The cybersecurity criticality tier may be a level of criticality of a relationship between the entity and the affiliate.

[0007] These and other objects, along with advantages and features of embodiments of the present invention herein disclosed, will become more apparent through reference to the following description, the figures, and the claims. Furthermore, it is to be understood that the features of the various embodiments described herein are not mutually exclusive and can exist in various combinations and permutations.

---

## Description

### BRIEF DESCRIPTION OF THE DRAWINGS

[0008] In the drawings, like reference characters generally refer to the same parts throughout the different views. Also, the drawings are not necessarily to scale, emphasis instead generally being placed upon illustrating the principles of the invention. In the following description, various embodiments of the present invention are described with reference to the following drawings, in which:

[0009] FIG. 1 is a block diagram of a risk management tool, according to some embodiments;

[0010] FIG. 2 depicts a flowchart of an entity-specific cybersecurity risk management method, according to some embodiments;

[0011] FIG. 3 depicts an example of a risk assessment matrix, according to some embodiments;

[0012] FIG. 4 depicts a flowchart of an entity-specific cybersecurity risk assessment method, according to some embodiments;

[0013] FIG. 5A depicts an example of a user interface for cyber security risk assessment, according to some embodiments;

[0014] FIG. 5B depicts an example of a user interface for cyber security risk assessment, according to some embodiments; and

[0015] FIG. 6 is a block diagram of an example computer system that may be used in implementing the technology described herein.

### DETAILED DESCRIPTION

[0016] The present disclosure is directed to methods and systems for cybersecurity risk mitigation and/or management, more specifically, methods and systems for accelerating an entity's protocols for monitoring and managing cybersecurity risks to determine and validate levels of assessment for affiliates having relationships with the entity.

[0017] Action plans corresponding to levels of the assessment may be specified for affiliates, for example, based on the affiliates' security ratings, the criticality of the entity's relationships to the affiliates, and/or one or more risk vector ratings or grades. Affiliates may be tiered (i.e. ranked) based on the criticality of the entity's relationships to the affiliates. In some embodiments, action plans may include questionnaires, where affiliate responses to the questionnaires may be mapped to risk vectors. Questionnaires may be curated based on the determined action plan. Risk vectors for each response may be combined to determine an indication of a state of each response to the questionnaire. In some embodiments, unsatisfactory responses may be automatically flagged based on a weighted combination of the risk vectors corresponding to each response. A flagged response may indicate that a security attribute of an affiliate requires further attention and/or improvement, enabling an entity to identify security risks associated with its affiliates.

[0018] The methods and related systems disclosed herein provide for significant improvements in monitoring and mitigation of cybersecurity threats to an entity, and constitute specific implementations of solutions to problems that arise when attempting to monitor and mitigate the cybersecurity risks faced by an entity. Thus, the improved cybersecurity mitigation techniques described herein constitute improvements to computer-related technology for reasons similar to those articulated by the Federal Circuit in *Finjan, Inc. v. Blue Coat Systems, Inc.* (Fed. Cir. 2018), among other reasons, and are not abstract ideas.

[0019] As used herein, an “affiliate” of a particular entity may be any individual, organization, corporation and/or other entity that interacts with, provides services to, and/or otherwise has a relationship to or with the particular entity.

[0020] As used herein, the “criticality” of an entity's relationship to an affiliate may be a measurement or characterization of the extent to which the entity's well-being (e.g., operational integrity, health, reputation, financial position, security state, etc.) is sensitive to (e.g., dependent

on) the affiliate's well-being, the frequency of such interactions, the volume of data exchanged between the entity and any given affiliate, and/or the sensitivity of such data.

[0021] An entity may monitor the security status (e.g., security ratings, security events, etc.) of one or more of the entity's affiliates. The monitored affiliates may be referred to herein as the entity's "portfolio" of affiliates. An entity's portfolio may include any number of the entity's affiliates (e.g., one or more, dozens, hundreds, thousands, etc.).

[0022] "Characteristics" of an entity (e.g., an affiliate or other entity) may include, without limitation, size (e.g., the number of employees or other members of the entity, the entity's market capitalization or annual revenues, etc.); the business sector (e.g., industry, sub-industry, etc.) in which the entity operates (e.g., legal services, technology, finance, etc.); age; rate of growth; North American Industry Classification System (NAICS) code; Standard Industrial Classification (SIC) code; a number of services provided by the entity; a security rating (e.g., as provided by BitSight Technologies, Inc. of Boston, Massachusetts, USA); a geographical location of the entity; a location of the entity based on one or more IP addresses associated with the entity (e.g., "geo IP" footprint); a number of Internet Protocol (IP) addresses associated with the entity; the technology used by the entity (e.g., server software, user software, etc.); one or more security risk types of an entity; and/or known competitors or entities similar to the particular entity based on the web activity of the entity. Values for one or more of the above-listed entity characteristics may be provided by the entity itself, obtained from third party sources (e.g., a firmographics data source, data from BuiltWith® Pty Ltd), and/or collected or extracted from publicly available information. In some embodiments, the values for one or more entity characteristics can be stored in a database.

[0023] A "security profile" of an entity may reflect the past, present, and/or future security characteristics of an entity. In some embodiments, the security profile may reflect security risks to which the entity is exposed balanced by the countermeasures that the entity has taken or can take to mitigate the security risk. As referred to herein, a security profile of an entity can include a "security rating" (e.g., "security score") for the entity. A security rating may be quantitative or qualitative. For example, a quantitative security rating may be expressed as a number within a predetermined range (e.g., between 250 and 900, as provided by BitSight Technologies, Inc. of Boston, Massachusetts, USA). Some non-limiting examples of techniques for determining security ratings of entities are described in U.S. patents application Ser. Nos. 16/802,232, 13/240,572, 15/142,677, and 16/514,771.

[0024] As used herein, "monitoring" an affiliate may refer to determining (e.g., obtaining) a security rating of the affiliate from time to time, identifying one or more activities or events relevant to the affiliate's security profile, etc. Some non-limiting examples of techniques for determining security ratings of entities are described in U.S. patents application Ser. Nos. 16/802,232, 13/240,572, 15/142,677, and 16/514,771.

Some Embodiments of Cybersecurity Risk Assessment Method

[0025] An entity's relationships to different affiliates may pose different levels of risk to the entity. Thus, it is often appropriate for an entity to adopt different risk management protocols for different affiliates, depending on characteristics of the entity, characteristics of the affiliates, the nature of the entity's relationship to the entity, and/or other factors. However, determining the most suitable risk management protocol for a given affiliate can be difficult and time-consuming, which can be exacerbated by an entity having relationships with a large number of affiliates. When an entity chooses an unsuitable risk management protocol for a given affiliate, resources may be wasted or significant risks may be ignored. Moreover, as characteristics change, the protocols may change, requiring ongoing reassessments of how a particular affiliate or group of affiliates may be monitored.

[0026] Thus, a tool for determining, executing, and validating the appropriate cybersecurity risk management protocols for an entity's various affiliates is needed. Referring to FIG. 1, an example of a risk management tool **100** is shown. In some embodiments, the risk management tool **100** may

recommend risk management protocols for various affiliates based, for example, on characteristics of the affiliate, characteristics of the entity, the nature of the entity's relationships to the affiliates, risk management protocols adopted by other entities for the same affiliates or similar affiliates, and/or other factors. The risk management protocols may specify, for example, (1) which of an entity's affiliates are to be prioritized for cybersecurity risk assessment, (2) what action(s) are to be taken with respect to an affiliate that poses a potential cybersecurity risk, and/or (3) under what conditions those action(s) are to be taken. In some embodiments, the risk management tool **100** may be included with a cybersecurity monitoring system of a risk management service provider. Some non-limiting examples of cybersecurity monitoring systems are described in U.S. patents application Ser. Nos. 16/802,232, 13/240,572, 15/142,677, and 16/514,771. In some embodiments, the risk management tool **100** may be communicatively coupled to a third party computing system. In some cases, the risk management tool may be coupled to more than one third party computing system.

[0027] Some embodiments of a risk management tool **100** are described below. In some embodiments, the risk management tool may include a tier recommendation module **110**, which may recommend assignment of an entity's affiliates (e.g., monitored affiliates, unmonitored affiliates, or monitored and unmonitored affiliates) to various "criticality tiers." The criticality tier to which an affiliate is assigned may indicate a level of criticality of the entity's relationship to the affiliate. For example, the criticality tier to which an entity assigns an affiliate may indicate the extent to which the entity's well-being (e.g., operational integrity, health, reputation, financial position, security state, etc.) is sensitive to (e.g., dependent on) the affiliate's well-being. In some embodiments, the tier recommendation module **110** may determine the recommended criticality tiers for an entity's affiliates by performing a risk management method **200** as described below with reference to FIG. 2.

[0028] In some embodiments, the risk management tool **100** may include a risk vector rating module **120**. The risk vector rating module **120** may obtain one or more risk vector ratings and/or grades for an entity's affiliates. Risk vector ratings or grades may be determined for a risk vector based on a metric (e.g., a measurement, value, number, or amount) or an evaluation (e.g., a categorical or binary determination) associated with the risk vector. The risk vector ratings or grades may be determined based on mapping the metric to one or more thresholds or ranges that are indicative of a risk vector rating or grade. The risk vector ratings or grades may be determined based on mapping the evaluation to one or more categories or partitions that are indicative of a risk vector rating or grade. Examples for determining security ratings and risk vector ratings or grades for an entity are described further below in the section titled "Security Ratings of Entities." A risk vector may be based on externally observable information for an entity that serves as a proxy (i.e. indicator) of a cyber security state of an entity (e.g., affiliate). This externally observable information can be categorized into observable subject areas (i.e. risk vectors), which can each be independently determined and/or characterized. For example, one possible proxy for entity vulnerability is the number of entity-owned IP addresses which are reported by third parties to be malicious. The greater the number of reports, the more likely the particular entity was vulnerable and had been compromised. Examples of risk vectors may include: [0029] an amount of capital investment in the security of the entity; [0030] a measure of employee training in the security of the entity; [0031] a measure of organization of entity personnel dedicated to information security; [0032] an amount of the entity's budget dedicated to information security; [0033] a number and/or severity of botnet infection instances of a computer system associated with the entity; [0034] a number of spam propagation instances originating from a computer network associated with the entity; [0035] a number of malware servers associated with the entity; [0036] a number of potentially exploited devices associated with the entity; [0037] a number of hosts authorized to send emails on behalf of each domain associated with the entity; [0038] a determination of whether a DomainKeys Identified Mail (DKIM) record exists for each domain associated with the entity

and/or a key length of a public key associated with a Domain Name System (DNS) record of each domain associated with the entity; [0039] an evaluation of a Secure Sockets Layer (SSL) certificate and/or a Transport Layer Security (TLS) certificate associated with a computer system of the entity; [0040] a number and/or type of service of open ports of a computer network associated with the entity; [0041] an evaluation of security-related fields of a header section of HTTP response messages of hosts associated with the entity; [0042] a rate at which vulnerabilities are patched in a computer network associated with the entity; [0043] an evaluation of file sharing traffic originating from a computer network associated with the entity; and/or [0044] a number of lost records and/or sensitivity of information in the lost records in a data breach of a computer system associated with the entity.

[0045] In some embodiments, risk vectors may be mapped to one or more ratings and/or grades, where each rating and/or grade corresponds to a state (e.g., poor, satisfactory, good, excellent) of a risk vector. The risk vector rating module **120** may obtain and/or store the mappings of ratings and/or grades to risk vectors for each of an entity's affiliates. In some embodiments, the ratings may be numerical ratings, e.g., 0-4, 0-5, 1-10, 1-100, etc. In some cases, high ratings (e.g., relative to a range of ratings) may correspond to positive state for a risk vector, while low ratings may correspond to a negative state for a risk vector. In some embodiments, the grades may be any suitable grades, e.g., "A", "B", "C", "D", or "F". A state of a risk vector mapped to an "A" letter grade may have the best or highest favorability, while a state of a risk vector mapped to an "F" letter grade may have the worst or lowest favorability. An example of risk vector grades with corresponding ratings is shown by Table 1:

TABLE-US-00001 TABLE 1 Risk Vector Grades & Ratings Risk Vector Grade Rating (R) A ("Positive") 4 B 3 C 2 D 1 F ("Negative") 0

[0046] As shown in Table 1, an "A" letter grade may correspond to a "4" rating, while an "F" letter grade may correspond to a "0" rating, where an "A" letter grade may reflect positively on the state of the risk vector and an "F" letter grade may reflect negatively on a state of the risk vector. The risk vector grades and ratings shown in Table 1 are examples and may be supplemented, modified, and/or removed.

[0047] In some embodiments, particular risk vectors may be associated with a weight (e.g., numerical weight). A particular risk vector may be weighted based on an assigned numerical value. Weightings may be based on any suitable range, e.g., 0-1, 0-5, 1-4, 1-10, etc. An example of risk vector weightings is shown by Table 2:

TABLE-US-00002 TABLE 2 Risk Vector Weighting Risk Vector Type Weight (W) Data breaches 4 Open ports 4 Botnet infections 3 Potentially exploited devices 3 File sharing 2 Other 1

[0048] As shown in Table 2, example risk vector types may include "data breaches", "open ports", "botnet infections", "potentially exploited devices", "file sharing", and "other". "Data breaches" may correspond to a risk vector for a number of lost records and/or sensitivity of information in the lost records in a data breach of a computer system associated with the entity. "Open ports" may correspond to a risk vector for a number and/or type of service of open ports of a computer network associated with the entity. "Botnet infections" may correspond to a risk vector for a number and/or severity of botnet infection instances of a computer system associated with the entity. "Potentially exploited devices" may correspond to a risk vector for a number of potentially exploited devices associated with an entity (e.g., affiliate). "File sharing" may correspond to a risk vector for an evaluation of file sharing traffic originating from a computer network associated with an entity (e.g., affiliate). "Other" may correspond to any other risk vector type as described herein. The risk vector types and weights shown in Table 2 are examples and may be supplemented, modified, and/or removed.

[0049] In some embodiments, the risk vector rating module **120** may receive and/or otherwise obtain risk vector information from security characteristics for an entity's affiliates as described below in the section titled "Security Ratings of Entities." Based on the received risk vector

information, the risk vector rating module **120** may store the received risk vector information with corresponding weights as described herein. Based on the risk vector information and corresponding weights, an weighted risk vector score may be determined by an assessment report generation module **140**.

[0050] In some embodiments, the risk management tool **100** may include a questionnaire management module **130**. The questionnaire management module **130** may manage one or more questionnaires that may be completed by an entity's affiliates. In some embodiments, the risk management tool **100** may send a questionnaire (e.g., full or partial questionnaire) or cause a third party computing system to send a questionnaire to an affiliate (e.g., via a computer network), such that the affiliate may complete the questionnaire by responding to one or more included questions. A questionnaire may include questions directed to evaluation of security assets, practices, and processes that an entity may wish to assess and measure. In some embodiments, each question may be mapped to a question identifier (ID). A question data store (i.e. question bank) of a computing system external to the risk management tool **100** may include a plurality of questions, where questions included in each of the one or more questionnaires are selected from the plurality of questions. In an example, a risk management service provider that provides the risk management tool **100** to an entity may operate a computing system that includes the question data store, where the risk management tool **100** and risk management service provider computing system are communicatively connected. In some cases, one or more questions of the plurality of questions may be mapped to one or more risk vectors as described herein. Questions may be added or removed to the plurality of questions of the question data store, such that the questionnaires available in the risk management tool **100** may be updated and/or otherwise modified. In an example, the questionnaire management module **130** may receive updated questionnaires from the computing system external to the risk management tool **100**, while existing questionnaires available in the questionnaire management module **130** may be removed. A questionnaire may include one or more characteristics as described below in the section titled “Some Embodiments of Action Plan Execution by Entities.”

[0051] In some embodiments, the risk management tool **100** may include an assessment report generation module **140**. The assessment report generation module **140** may generate one or more assessments reports corresponding to completed questionnaires, where a completed questionnaire was directed to an affiliate of an entity. The assessment report generation module **140** may generate an assessment report by performing a risk assessment method **400** as described below with reference to FIG. 4. As a part of an action plan, an entity may send or cause a third party computing system to send an assessment or questionnaire (e.g., from the questionnaire management module **130**) to an affiliate for completion. An assessment report may include one or more responses from an affiliate, where each response is directed to a question include in a questionnaire. In some embodiments, particular questions of a questionnaire may be mapped to the one or more risk vectors and risk vector ratings or grades. In some embodiments, a particular question may be mapped to more than one risk vector and risk vector rating or grade. In an example, a question may be mapped to two risk vectors having risk vector ratings ranging from 0-4 as described herein with respect to Table 1.

[0052] In some embodiments, the assessment report generation module **140** may generate one or more weighted risk vector scores. A weighted risk vector score may correspond to a single question included in a questionnaire, where the weighted risk vector score may be a function of the risk vector ratings mapped to the question. The assessment report generation module **140** may generate weighted risk vector scores for questions that are mapped to one or more risk vectors. In an example, the assessment report generation module **140** may generate a weighted risk vector score according to Equation 1:

[00001] 
$$\text{WeightedAverageScore} = \frac{W_1R_1 + W_2R_2 + \dots + W_nR_n}{W_1 + W_2 + \dots + W_n} \quad \text{Equation 1}$$



[0053] As shown in Equation 1, the weighted risk vector score (“Weighted Average Score”) may be determined based on a function of a weight “W” and a risk vector rating “R”. The weight [0054] “W” may be mapped to each risk vector and may be configured (e.g., preconfigured) in the risk management tool **100** (e.g., by a user or a system administrator of a risk management service provider). In an example, for a question that is mapped to one risk vector, the weighted risk vector score may be equivalent to the risk vector rating “R” corresponding to the risk vector. As shown in Equation 1, “n” may be a number of risk vectors corresponding to a question for which a weighted risk vector score is calculated. In an example, for a question mapped to three risk vectors, three weights “W1”, “W2”, and “W3” and three risk vector ratings “R1”, “R2”, and “R3” may be included in Equation 1. In some embodiments, alternate generation methods for a weighted risk vector score may be possible.

[0055] In some embodiments, based on generating one or more weighted risk vector scores, the assessment report generation module **140** may compare the one or more weighted risk vector scores to a configured threshold. The comparison to the configured threshold may provide an indication of whether the risk vector rating(s) mapped to the question is/are indicative of poor and/or risky cyber security practices. In an example, the configured threshold may be 3. If a weighted risk vector score is less than or equal to the configured threshold, the assessment report generation module **140** may flag the question corresponding to the weighted risk vector score. Flagging a question may indicate that the question requires further attention and/or remediation (e.g., due poor and/or risky cyber security practices indicated by the risk vector rating(s) mapped to the question). If a weighted risk vector score is greater than the configured threshold, the assessment report generation module **140** may not flag the question corresponding to the weighted risk vector score. Not flagging a question may indicate that the risk vectors rating(s) mapped to the question is/are indicative of satisfactory cyber security practices associated with the response. As an example, an entity may respond to a first question in a questionnaire, where the first question is mapped to two risk vectors: Botnet infections (W1=3) and Open ports (W1=4). The entity may have a grade of D for both risk vectors (R1=R2=1), such that Equation 1 yields a weighted risk vector score of 1. Based comparing the weighted risk vector score of 1 to the configured threshold of 3, the first question in the questionnaire may be flagged by the assessment report generation module **140** based on the weighted risk vector being less than the configured threshold. Using flagged questions included in the generated assessment reports, entities may identify affiliates with poor and/or risky cyber security practices, as well as the specific areas in which the affiliates may require risk mitigation and/or remediation.

[0056] In some embodiments, the risk management tool **100** may be implemented as software executed on one or more computer systems **800**. For example, the risk management tool may be implemented as software executed on an entity's computer systems or a third party entity's computer systems, where the third party entity (e.g., risk management service provider) provides services to the entity. In some embodiments, the risk management tool **100** may provide a user interface **150**. The user interface **150** may present (e.g., display) information regarding the security states of an entity's affiliates (e.g., the cybersecurity risks posed by the entity's affiliates) and/or the entity's risk mitigation plans with respect to various affiliates.

[0057] In some embodiments, the user interface **150** may provide interactive components whereby a user may interact with the tier recommendation module **110**. For example, by interacting with a user interface **150**, the user may question the tier recommendation module **110** regarding the recommended criticality tier(s) for one or more of the entity's affiliates. In response to such a question, the tier recommendation module **110** may obtain the recommended criticality tier(s) for the specified affiliates (e.g., by performing the risk management method **200**, or by retrieving previously-determined criticality tier recommendations from a storage device) and provide those recommendations to the user via the user interface **150**.

[0058] In some embodiments, the user interface **150** may provide interactive components whereby

a user may interact with the risk vector rating module **120**. For example, by interacting with a user interface **150**, the user may review ratings, grades, and/or weightings mapped to risk vectors for each of an entity's affiliates.

[0059] In some embodiments, the user interface **150** may provide interactive components whereby a user may interact with the questionnaire management module **130**. For example, a user may access questionnaires available to send or cause to send to an entity's affiliate as a part of an action plan. By interacting with the user interface **150**, a user may send or cause a third party computing system to send a questionnaire to an affiliate from the questionnaire management module **130**.

[0060] In some embodiments, the user interface **150** may provide interactive components whereby a user may interact with the assessment report generation module **140**. For example, by interacting with a user interface **150**, the user view assessment reports corresponding to completed assessments and/or questionnaires from an entity's affiliates. The user may review responses to questions include in the assessments and/or questionnaires and may review the risk vectors mapped to each question and response. Based on reviewing the responses to questions, the user may validate the responses from the affiliate (e.g., by comparing the response to externally observed data). The user may review weighted risk scores corresponding to particular questions and responses. If a weighted risk score is less than or equal to the configured threshold, the user may view a flag indication displayed with the question corresponding to the weighted risk score.

[0061] Some embodiments and/or applications of the tier recommendation module **110**, the risk vector rating module **120**, the questionnaire management module **130**, the assessment report generation module **140**, and the user interface **150** are described in further detail below. In addition, some embodiments of a risk management method **200** are described below.

[0062] The tier recommendation module **110** may recommend assignment of one or more (e.g., all) of an entity's affiliates to various "criticality tiers." In some embodiments, the risk management tool **100** may provide tiering recommendations to a user (e.g., via the user interface **150**), who may then adopt one or more of the recommendations (e.g., by providing user input indicating acceptance of said recommendations) and/or adjust one or more of the recommendations (e.g., by providing user input overriding the recommended criticality tiers for one or more of the entity's affiliates). In some embodiments, the tier recommendation tool **110** may provide the tiering recommendations for an entity's affiliates during an onboarding process for an entity that is establishing or updating risk management protocols with respect to its affiliates.

[0063] The risk management tool **100** may support assignment of an entity's affiliates to any suitable number of criticality tiers (e.g., 2-10 tiers, 2 tiers, 3 tiers, 5 tiers, etc.). The tiers may have any suitable labels, and the criticality levels corresponding to the tiers may have any suitable relationship to the tier labels. For example, the risk management tool **100** may support 3 criticality tiers, which may be referred to as Tier 1, Tier 2, and Tier 3, with Tier 1 affiliates being most critical to an entity's well-being, Tier 2 affiliates being moderately critical to an entity's well-being, and Tier 3 affiliates being least critical to an entity's well-being. Unless otherwise noted, the examples described herein are based on the foregoing configuration of tiers. However, alternative tiering configurations are possible.

[0064] In some embodiments, tier recommendation module **110** (or "tier recommender" **110**) uses one or more models (e.g., mathematical, statistical, and/or machine-learned models) to generate affiliate tiering recommendations for entities. For example, the tier recommender **110** may use a single model to generate affiliate tiering recommendations for all entities. Alternatively, the tier recommender **110** may use different models to generate affiliate tiering recommendations for different sets of entities (e.g., entity peer groups or other sets of entities). Examples of generating affiliate tiering recommendations for different sets of entities can be found in at least U.S. patent application Ser. No. 17/119,822 filed on Dec. 11, 2020 and titled "Systems And Methods For Cybersecurity Risk Mitigation And Management," which is incorporated herein by reference in its entirety.

[0065] As previously mentioned, the risk management tool may provide a user interface **150**, which may present information regarding the security states of an entity's affiliates and/or the entity's risk mitigation plans with respect to various affiliates. In some embodiments, the user interface **150** may provide interactive components whereby a user may interact with the tier recommendation module **110**, the risk vector rating module **120**, the questionnaire management module **130**, and/or the assessment report generation module **140**.

[0066] FIG. 2 depicts an entity-specific cybersecurity risk management method **200**, according to some embodiments. In the example of FIG. 2, the risk management method **200** includes steps **202-212**, which are described below. In some embodiments, the risk management method **200** is performed, for example, by a risk management tool **100** (e.g., by a tier recommendation module **110**, a risk vector rating module **120**, and/or a questionnaire management module **130** of the risk monitoring tool **100**).

[0067] In step **202** of the method **200**, the risk management tool **100** recommends, for each of a plurality of affiliates of an entity, a respective cybersecurity criticality tier. The criticality tier may be selected from a set of criticality tiers. Recommending criticality tiers for the plurality of affiliates may involve identifying the recommended criticality tiers for the affiliates, and presenting the recommended criticality tiers for the affiliates via a user interface component (e.g., the user interface **150**). The recommended criticality tiers for the affiliates may be identified using a machine-learned model. The machine-learned model may be selected based on a peer group of the entity. The peer group of the entity may be identified based on one or more characteristics of the entity (e.g., the entity's size, an industry in which the entity operates, and/or a sector in which the entity operates). The machine-learned model may identify a particular recommended criticality tier for a particular affiliate based on (1) one or more characteristics of the particular affiliate and (2) an analysis of a plurality of tier assignments made by a plurality of peer entities included in the peer group, wherein each of the tier assignments is an assignment of an affiliate of at least one of the peer entities to a criticality tier. In some embodiments, the model's identification of a criticality tier for an affiliate may also be based on one or more characteristics of the entity (e.g., the size of the entity's portfolio of monitored affiliates). In some embodiments, the machine-learned model is a regression model (e.g., a linear regression model).

[0068] In some embodiments, a process for identifying the recommended criticality tiers for a plurality of affiliates includes steps of (1) generating, using the machine-learned model, respective criticality scores for the plurality of affiliates; (2) normalizing the criticality scores, thereby generating normalized criticality scores within a bounded range; (3) partitioning the normalized criticality scores into a number of partitions equal to the number of criticality tiers, wherein each of the partitions corresponds to a respective one of the criticality tiers; and (4) for each affiliate, selecting the criticality tier corresponding to the partition to which the normalized criticality score of the affiliate is assigned, and identifying the selected criticality tier as the recommended criticality tier for the affiliate.

[0069] In step **204** of the method **200**, the risk management tool **100** receives user input adjusting and/or adopting the recommended criticality tier for each of the affiliates. Such user input may be received, for example, via a component of a user interface **150**.

[0070] In step **206** of the method **200**, the risk management tool **100** assigns each of the affiliates to the respective criticality tier adjusted or adopted in step **204**. The risk management tool **100** may make these assignments in response to user input received via a component of a user interface **150**.

[0071] In step **208** of the method **200**, the risk management tool **100** obtains respective security ratings for each of the affiliates. Some techniques for obtaining security ratings for entities (e.g., affiliates) are described above.

[0072] In step **210** of the method **200**, the risk management tool **100** obtains risk vector ratings or grades for each risk vector mapped to each of the affiliates. Risk vector ratings or grades may be obtained based on states of risk vectors derived from security characteristics of each of the

affiliates. Some techniques for obtaining risk vector ratings and grades are described below in the section titled “Security Ratings of Entities.”

[0073] In step **212**, the risk management tool **100** maps each of the affiliates to one or more action plans. The mapping of the one or more action plans may be based on a risk assessment matrix, however, any suitable mapping of an affiliate to an action plan based on a criticality tier, security rating, and risk vector rating or grade may be used. The risk assessment matrix may be a two-dimensional matrix that includes one or more partitions corresponding to a first dimension and a second dimension. Each partition of the risk assessment matrix may include an action plan. Each action plan may correspond to a level of risk assessment to be performed for a particular affiliate. In some embodiments, a first dimension of the risk management matrix may correspond to a range of security ratings and/or a set of thresholds corresponding to risk vector ratings or grades. The security ratings may be indicative of a cyber security state of an affiliate. In some embodiments, a second dimension of the risk assessment matrix may include a set of one or more criticality tiers, where an affiliate may be mapped to an action plan based on their assigned criticality tier.

[0074] In some embodiments, as a part of mapping each of the affiliates to one or more action plans, the risk management tool **100** displays a user interface component configured to show a visualization of a cybersecurity risk management plan of the entity with respect to the plurality of affiliates. The visualization of the cybersecurity risk management plan may include the risk assessment matrix, such that the first dimension of the matrix corresponds to a range of security ratings and/or a set of thresholds corresponding to risk vector ratings or grades, and the second dimension of the matrix corresponds to a set of criticality tiers.

[0075] The risk management plan may partition the affiliates into a plurality of affiliate sets within the risk assessment matrix based on the security ratings, risk vector ratings or grades, and the assigned criticality tiers of the affiliates. The risk management plan may specify, for each of the affiliate sets, an action plan to be taken by the entity with respect to the affiliates in the affiliate set. The action plan to be taken by the entity with respect to the affiliates in a given set may include monitoring the affiliates, investigating the affiliates, and/or contacting the affiliates.

[0076] FIG. **3** depicts an example of a risk assessment matrix **300** by which an action plan may be mapped to an affiliate. The risk assessment matrix **300** may be a two-dimensional matrix that includes one or more partitions **350** corresponding to a first dimension and a second dimension. Included in each partition **350** may be an action plan that may be mapped to an entity. For example, as shown in FIG. **3**, partition **350e** indicates an action plan that includes a partial questionnaire. The action plans shown in FIG. **3** are example, such that any suitable action plan may be associated with a partition **350** of the risk assessment matrix **300**. As shown in FIG. **3**, the risk assessment matrix **300** may have a first dimension **310** corresponding to a range of security ratings and/or a set of thresholds corresponding to risk vector ratings or grades. The ranges of security ratings and risk vector grade thresholds shown in FIG. **3** are examples, such that any combination of suitable ranges for security ratings and thresholds for risk vector ratings or grades may be used to map an affiliate to an action plan. As shown in FIG. **3**, a second dimension **330** of the risk assessment matrix **300** may include a set of criticality tiers. The three criticality tiers (“Tier 1”, “Tier 2”, and “Tier 3”) shown in FIG. **3** are examples and any suitable number of criticality tiers may be used for the risk assessment matrix **300**. As described herein with respect to the risk management method **200**, an affiliate may be mapped to an action plan of a partition **350** of the risk assessment matrix **300** based on a combination of an affiliates criticality tier, security rating, and risk vector rating(s) or grade(s).  
Some Embodiments of Action Plan Execution by Entities

[0077] In some embodiments, as described herein, an entity may adopt different risk management protocols for different affiliates, depending on characteristics of the entity, characteristics of the affiliates, the nature of the entity's relationship to the entity, and/or other factors. Accordingly, affiliates may be mapped to one or more action plans as a part of the risk management protocols based on the security ratings, risk vector ratings or grades, and the assigned criticality tiers of the

affiliates. Such action plans may include monitoring the affiliates, investigating the affiliates, and/or contacting the affiliates, as well as terminating relationships with affiliates.

[0078] In some embodiments, an action plan may require an entity (e.g., affiliate) to provide an entity attestation, where the entity may attest to one or more standard cybersecurity practices or frameworks. Examples of standard cyber security practices or frames may include those defined by the NIST, ISO, SOC, etc. In some embodiments, an action plan may include onboarding, where an entity may allow an affiliate to establish or maintain a relationship with the entity without further assessment at that instance. In some embodiments, an action plan may include an onsite audit, where an entity may directly engage with an affiliate (e.g., at an affiliate's office, data center, information technology center, etc.) and/or an affiliate's computing system(s) to review and evaluate the affiliate's security practices. In some embodiments, an action plan may include an Enable Vendor Access (EVA) outreach, where an entity may invite an affiliate to access the risk management tool **100** and/or a third party application to collaborate and/or address the affiliate's cybersecurity practices. In some embodiments, an action plan may include a refusal, where an entity may terminate or choose not to establish a relationship with an affiliate. An entity may refuse an affiliate based on a combination of risky security ratings, risky risk vector ratings or grades, and a high criticality tier. In an example, based on the risk assessment matrix, a first affiliate having a security rating of less than **500** and a moderate criticality tier (e.g., Tier 2) may be assigned an onsite audit as an action plan, while a second affiliate having a security rating of less than **500** and a high criticality tier (e.g., Tier 1) may be assigned a refusal as an action plan.

[0079] In some embodiments, an action plan may include sending a questionnaire (e.g., full or partial questionnaire) to an affiliate, such that the affiliate may complete the questionnaire by responding to one or more included questions. Questionnaires available to users of the risk management tool **100** may be stored or available via the questionnaire management module **130** as described herein. In some embodiments, a questionnaire may include questions directed to evaluation of security assets, practices, and processes of an entity (e.g., affiliate), such that an entity may evaluate the security practices of affiliates having relationships with the entity. Responses to the questionnaires may provide insights on an entity's (e.g., affiliate's) security controls and procedures, as well as compliance with internal and regulatory cyber security requirements. Examples of questionnaires may include standard free assessment questionnaires (e.g., a National Institute of Standards and Technology (NIST) questionnaire), commercial assessment questionnaires (e.g., a Standardized Information Gathering (SIG) questionnaire), and customized questionnaires for an entity. Customized questionnaires for an entity may be generated by a third party entity (e.g., a risk management service provider). In an example, a risk management service provider may send one or more questionnaires to the risk management tool **100**, such that the available questionnaires at the risk management tool **100** may be sent by an entity to affiliates based on determined action plans.

[0080] In some embodiments, questionnaires (e.g., standard, commercial, or customized) may be accessible in the risk management tool **100** (e.g., via the questionnaire management module **130**) or in a third party computing system. A questionnaire may include one or more sections, with each section including one or more subsections. Each subsection may include one or more questions for an entity (e.g., affiliate) directed to the entity's security practices. A response may be input for each question of a custom questionnaire. Each response may indicate a state (e.g., a self-evaluation) of the entity's (e.g., affiliate's) cyber security practices associated with the question. In some embodiments, a response to a question may include a discrete, preconfigured response. For example, a response to a question may include a selection of a response from five selectable, preconfigured responses. In some embodiments, a response may include a configurable response, where a user may input or otherwise configure a response to the question. As described herein, a question may be mapped to one or more risk vectors with corresponding risk vector ratings or grades. In some embodiments, a question may not be mapped to one or more risk vectors.

[0081] In some embodiments, an affiliate may complete a questionnaire and send the completed questionnaire to the entity. An affiliate may complete the questionnaire within the risk management tool **100** and/or within a third party computing system. The completed questionnaire may be received by the entity at the risk management tool **100** (e.g., via a computer network) or via a third party computing system. The completed questionnaire may be available via the user interface **150** and may be stored by the questionnaire management module **130**, the assessment report generation module **140**, or a third party computing system. A user may view the completed questionnaire at the user interface **150**. In some embodiments, the assessment report generation module **140** may generate an assessment report based on the completed questionnaire. The assessment report may include the questionnaire with each of the questions and the corresponding responses (e.g., selected responses and/or configured responses). The assessment report may include an indication of the risk vector(s) mapped each applicable question and the corresponding risk ratings or grades for the risk vectors. The assessment report may include weighted risk vector scores for applicable questions as described herein. Questions having weighted risk vector scores less than or equal to the configured threshold may be flagged in the assessment report as described herein. The questions having weighted risk vector scores less than or equal to the configured threshold may include a flag indication. The assessment report may include one or more characteristics as described below with respect to FIGS. 5A and 5B.

[0082] In some embodiments, the assessment report may include risk vector ratings or grades determined based on security characteristics of each of the affiliates (e.g., as described herein with respect to step **210** of the method **200**). By determining risk vector ratings or grades from the security characteristics of an affiliate, an entity may validate an affiliate's responses to the questionnaire. If a sufficiently large discrepancy exists between a response to a question and the risk vector rating(s) or grade(s) mapped to the question, an entity may contact and/or investigate an affiliate. In some cases, based on a sufficiently large discrepancy, the entity may modify its risk management protocols with regard to the affiliate.

[0083] In some embodiments, an assessment report may include one or more filters. The one or more filters may include filtering the assessment report by section, subsection, flagged responses, risk vector, risk vector rating or grade, and/or questions that are mapped to risk vectors. In some embodiments, an assessment report may be generated in a comma-separated value (CSV) format for review at the user interface **150** or in a third party application. A user may download an assessment report from the risk management tool **100** in a .csv format or any other suitable format for further review external to the risk management tool **100**.

[0084] FIG. 4 depicts an entity-specific cybersecurity risk assessment method **400**, according to some embodiments. In the example of FIG. 4, the risk management method **400** includes steps **402-416**, which are described below. In some embodiments, the risk assessment method **400** is performed, for example, by a risk management tool **100** (e.g., by a risk vector rating module **120**, a questionnaire management module **130**, and/or an assessment report generation module **140** of the risk monitoring tool **100**). The risk assessment method **400** may be suitable for assessing an entity's affiliate based on sending a questionnaire to the affiliate. As indicated by the loop header **406**, steps **408**, **410**, and **412** of the method **400** may be performed for question of a questionnaire that is mapped to one or more risk vectors. For simplicity, the following paragraphs describe steps **408**, **410**, and **412** with reference to a single question of a questionnaire. However, one of ordinary skill in the art will appreciate that steps **408**, **410**, and **412** each may be performed in parallel by the risk management tool **100**.

[0085] In step **402** of the method **400**, an entity may send a questionnaire to an affiliate. In some cases, the entity may send the questionnaire to the affiliate via the risk management tool **100** by interacting with the user interface **150**. In some cases, the entity may cause a third party computing system to send the questionnaire to the affiliate. The questionnaire may be sent to a computing system associated with the affiliate via a network. In an example, the questionnaire may be sent to

a third party computing system that is accessible by the affiliate. In some embodiments, the questionnaire may be selected based on mapping an affiliate to an action plan by performing a risk management method **200** as described above with reference to FIG. **2**. The questionnaire may be a full questionnaire or a partial questionnaire, where a partial questionnaire includes a subset of questions included in a full questionnaire. The questionnaire may be any one of a standard free assessment questionnaire, a commercial assessment questionnaires, or a customized questionnaire. The questionnaire may include one or more characteristics as described herein.

[0086] In step **404** of the method **400**, the entity may receive a completed questionnaire from the affiliate. In some cases, the entity may receive the completed questionnaire from the affiliate via the risk management tool **100** by interacting with the user interface **150**. In some cases, the entity may receive the completed questionnaire from the affiliate via a third party computing system. The completed questionnaire may be sent to the risk management tool **100** via a computing system associated with and/or accessible by the affiliate via a network. The completed questionnaire may include one or more responses to the one or more included questions.

[0087] With respect to each question that is mapped to one or more risk vectors, in step **408** of the method **400**, the risk management tool **100** may map one or more risk vector ratings or grades to a question of the completed questionnaire. In some embodiments, a question in the questionnaire may be mapped to one or more risk vectors. In some embodiments, a question in the questionnaire may not be mapped to one or more risk vectors. Elements of the risk management module **100** (e.g., the risk vector rating module **120**, the questionnaire management module **130**, or the assessment report generation module **140**) may store the mappings of the one or more risk vector ratings to the one or more questions.

[0088] In step **410** of the method **400**, the risk management tool **100** may determine a weighted risk score for the question. In some embodiments, the risk management tool **100** may determine a weighted risk score as described herein with respect to Table 1, Table 2, and Equation 1. In some embodiments, the risk management tool **100** may determine a weighted risk score according to alternative techniques. For a response mapped to one risk vector rating, the weighted risk score may be equivalent to the mapped risk vector rating. For a response mapped to more than one risk vector rating, the weighted risk score may be determined based on a weighted combination of the risk vector ratings and risk vector weights.

[0089] In step **412** of the method **400**, the risk management tool **100** may compare the weighted risk vector score to a configured threshold to determine whether to flag the question. If the weighted risk vector score is greater than the configured threshold, the risk management tool **100** may not flag the question. If the weighted risk vector score is less than or equal to the configured threshold, the risk management tool **100** may flag the question. Flagging a question may indicate that a question requires further attention from the entity due to poor and/or risky cyber security practices of an affiliate indicated by the question. The configured threshold may be selected by an entity (e.g., via the user interface **150**) based on their risk tolerance. A higher configured threshold may cause fewer responses to be flagged by the risk management tool **100**, while a lower configured threshold may cause more responses to be flagged by the risk management module

[0090] In step **414** of the method **400**, the risk management tool **100** may generate an assessment report. In some embodiments, the risk management tool **100** may generate the assessment report based on receiving an input from a user at the user interface **150**. A user may review the assessment report (e.g., in the user interface **150** or in an exported CSV file) using one or more filters as described herein. A user may review risk vector ratings or grades for an affiliate and an affiliate's responses to the questionnaire, such that the user may validate an affiliate's responses to the questionnaire as described herein.

[0091] As described herein, the risk management tool **100** may provide a user interface **150**. In some embodiments, an assessment report may be reviewed in the user interface **150** of the risk management tool or as a part of an application programming interface (API) included in a third

party computing system. Referring to FIGS. 5A and 5B, non-limiting embodiments of a user interface (UI) component **501** for cybersecurity risk assessment are illustrated. In particular, FIGS. 5A and 5B show an example of a UI component **501** for a generated assessment report. The UI component **501** may be displayed via the user interface **150**. The UI component **501** may provide a visual representation of a risk assessment report generated from a questionnaire completed by an entity's affiliate. The UI component **501** may include visual representations of configurable filters **502**, sections and subsections **504**, question identifiers (IDs) **506**, questions **508**, risk vectors and risk vector grades **510** mapped to each question **508**, and flags **512**, and context information **514** associated with a question **508**. As shown in FIG. 5B, a question **508** may be selected in the UI component **501**, which may cause the UI component **501** to display a section and subsection **504** associated with the question **508**, a question ID **506**, the question **508**, risk vectors and risk vector grades **510**, a flag **512**, and context information **514** for the question **508**.

#### Security Ratings of Entities

[0092] In some embodiments, the security characteristics of an entity's network(s) can be evaluated to assess the entity's cybersecurity states, and/or how the addition or selective removal of affiliates having relationships with the entity may impact a security rating. Specifically, the security characteristics can be evaluated to determine the entity's security rating based on changes to an entity's affiliates and/or risk vector ratings or grades associated with an entity's affiliates, enabling an entity to identify potential areas of risk associated with certain affiliates. The entity's security rating and an affiliate's security rating can be provided to the entity as a measure of that entity's risk of security breaches and/or past security record.

[0093] In various embodiments, networks can be characterized for each individual entity. In some embodiments, in parent-child entity relationships (e.g., parent company and subsidiary company), an IP address is attributed to a parent entity's subsidiary and the parent entity. For security ratings purposes, an IP address and/or computer network would be associated with both the entity and any other entities that are parents of that entity.

[0094] Examples of determining and/or evaluating the security characteristics of entities and associated IP addresses, and determining security ratings and risk vector ratings/grades of entities based on the security characteristics can be found in at least U.S. Publication No. 2016/0205126 published on Jul. 14, 2016 and titled "Information Technology Security Assessment System," U.S. Pat. No. 9,973,524 issued on May 15, 2018 and titled "Information Technology Security Assessment System," U.S. Pat. No. 9,830,569 issued on Nov. 28, 2017 and titled "Security Assessment Using Service Provider Digital Asset Information," and

[0095] U.S. patent application Ser. No. 16/514,771 filed on Jul. 17, 2019 and titled "Systems and methods for generating security improvement plans for entities", all of which are incorporated herein by reference in their entireties.

[0096] In some embodiments, determining security risk of entities uses externally observable information as proxies for (i) the effectiveness of the overall security performance of the policies and controls that entity implements and exercises and/or (ii) the vulnerability of the entity to security risk. This externally observable information can be categorized into observable subject areas, or "risk vectors" as described herein, which can each be independently determined and/or characterized. For example, one possible proxy for entity vulnerability is the number of entity-owned IP addresses which are reported by third parties to be malicious. The greater the number of reports, the more likely the particular entity was vulnerable and had been compromised.

[0097] In some embodiments, received data for an entity can include two or more subject areas (e.g., of those listed above in the section titled "Some Embodiments of Cybersecurity Risk Assessment Method"). In some cases, determining the security rating for an entity can include determining the relationship between the first subject area and the second subject area. This relationship can be stored in a database and accessed for use. For example, the number of botnet infections of an entity may be correlated with the number of potentially exploited devices



associated with the entity. This correlation can be stored and referenced in the future. In some embodiments, the security characteristic of an entity is associated with, related to, or equal to the security rating of that entity (e.g., on a scale from 250 to 900, as provided by BitSight Technologies, Inc., Boston, MA).

[0098] In some embodiments, to compute the security ratings for an entity, obtained data pertaining to the IT assets owned by that entity may be aggregated. For example, IT assets can include the IP addresses controlled by the entity and obtained data can include the activity associated with those IP addresses. To determine externally observable information about IP address-based assets, one or more IP addresses can be associated with an entity. The data may be processed to determine additional information. For example, processing may yield a list of IP addresses for an entity that has demonstrated suspicious or malicious behavior or fails to follow best security practices for the given reference data point. Similar methods can be used for other types of assets, e.g., domain-based assets, or other information for which an asset can be determined to be associated to an organization. Using these techniques, information about that asset can be associated with the entity.

[0099] The exemplary security ratings systems and methods may be configured to account for differences in data sources and types. Given each data source's potentially unique insight of an entity, there can be two or more techniques used to take advantage of the respective data. Data source-specific modeling techniques may be applied to some or all of the data sources to demonstrate feasibility and validate the approach for each data source and modeling technique.

[0100] In some embodiments, the combination of two or more vectors may produce a security rating that reflects the effectiveness of an entity's security efforts. The determination of individual vectors and the overall security rating can be influenced by security best-practices as promoted by standardized and accepted cybersecurity frameworks. In some embodiments, evidence of security compromise can be used to understand the specific impact the individual vectors have on the security rating of the entity. For instance, correlation between sources of externally observed information can be used to determine the impact of vectors. For example, the vectors representing evidence of compromised workstations (owned or controlled by an entity) may represent a significant portion of the entity's ability to implement security controls correctly, and thus may influence the entity's security rating more than other types of information.

#### Computer-Based Implementations

[0101] In some examples, some or all of the processing described above can be carried out on a personal computing device, on one or more centralized computing devices, or via cloud-based processing by one or more servers. In some examples, some types of processing occur on one device and other types of processing occur on another device. In some examples, some or all of the data described above can be stored on a personal computing device, in data storage hosted on one or more centralized computing devices, or via cloud-based storage. In some examples, some data are stored in one location and other data are stored in another location. In some examples, quantum computing can be used. In some examples, functional programming languages can be used. In some examples, electrical memory, such as flash-based memory, can be used.

[0102] FIG. 6 is a block diagram of an example computer system **600** that may be used in implementing the technology described in this document. General-purpose computers, network appliances, mobile devices, or other electronic systems may also include at least portions of the system **600**. The system **600** includes a processor **610**, a memory **620**, a storage device **630**, and an input/output device **640**. Each of the components **610**, **620**, **630**, and **640** may be interconnected, for example, using a system bus **650**. The processor **610** is capable of processing instructions for execution within the system **600**. In some implementations, the processor **610** is a single-threaded processor. In some implementations, the processor **610** is a multi-threaded processor. The processor **610** is capable of processing instructions stored in the memory **620** or on the storage device **630**.

[0103] The memory **620** stores information within the system **600**. In some implementations, the memory **620** is a non-transitory computer-readable medium. In some implementations, the memory

**620** is a volatile memory unit. In some implementations, the memory **620** is a non-volatile memory unit.

[0104] The storage device **630** is capable of providing mass storage for the system **600**. In some implementations, the storage device **630** is a non-transitory computer-readable medium. In various different implementations, the storage device **630** may include, for example, a hard disk device, an optical disk device, a solid-state drive, a flash drive, or some other large capacity storage device. For example, the storage device may store long-term data (e.g., database data, file system data, etc.). The input/output device **640** provides input/output operations for the system **600**. In some implementations, the input/output device **640** may include one or more of a network interface devices, e.g., an Ethernet card, a serial communication device, e.g., an RS-232 port, and/or a wireless interface device, e.g., an 802.11 card, a 3G wireless modem, or a 4G wireless modem. In some implementations, the input/output device may include driver devices configured to receive input data and send output data to other input/output devices, e.g., keyboard, printer and display devices **660**. In some examples, mobile computing devices, mobile communication devices, and other devices may be used.

[0105] In some implementations, at least a portion of the approaches described above may be realized by instructions that upon execution cause one or more processing devices to carry out the processes and functions described above. Such instructions may include, for example, interpreted instructions such as script instructions, or executable code, or other instructions stored in a non-transitory computer readable medium. The storage device **630** may be implemented in a distributed way over a network, such as a server farm or a set of widely distributed servers, or may be implemented in a single computing device.

[0106] Although an example processing system has been described in FIG. **6**, embodiments of the subject matter, functional operations and processes described in this specification can be implemented in other types of digital electronic circuitry, in tangibly-embodied computer software or firmware, in computer hardware, including the structures disclosed in this specification and their structural equivalents, or in combinations of one or more of them.

[0107] Embodiments of the subject matter described in this specification can be implemented as one or more computer programs, i.e., one or more modules of computer program instructions encoded on a tangible nonvolatile program carrier for execution by, or to control the operation of, data processing apparatus. Alternatively or in addition, the program instructions can be encoded on an artificially generated propagated signal, e.g., a machine-generated electrical, optical, or electromagnetic signal that is generated to encode information for transmission to suitable receiver apparatus for execution by a data processing apparatus. The computer storage medium can be a machine-readable storage device, a machine-readable storage substrate, a random or serial access memory device, or a combination of one or more of them.

[0108] The term “system” may encompass all kinds of apparatus, devices, and machines for processing data, including by way of example a programmable processor, a computer, or multiple processors or computers. A processing system may include special purpose logic circuitry, e.g., an FPGA (field programmable gate array) or an ASIC (application specific integrated circuit). A processing system may include, in addition to hardware, code that creates an execution environment for the computer program in question, e.g., code that constitutes processor firmware, a protocol stack, a database management system, an operating system, or a combination of one or more of them.

[0109] A computer program (which may also be referred to or described as a program, software, a software application, a module, a software module, a script, or code) can be written in any form of programming language, including compiled or interpreted languages, or declarative or procedural languages, and it can be deployed in any form, including as a standalone program or as a module, component, subroutine, or other unit suitable for use in a computing environment. A computer program may, but need not, correspond to a file in a file system. A program can be stored in a

portion of a file that holds other programs or data (e.g., one or more scripts stored in a markup language document), in a single file dedicated to the program in question, or in multiple coordinated files (e.g., files that store one or more modules, sub programs, or portions of code). A computer program can be deployed to be executed on one computer or on multiple computers that are located at one site or distributed across multiple sites and interconnected by a communication network.

[0110] The processes and logic flows described in this specification can be performed by one or more programmable computers executing one or more computer programs to perform functions by operating on input data and generating output. The processes and logic flows can also be performed by, and apparatus can also be implemented as, special purpose logic circuitry, e.g., an FPGA (field programmable gate array) or an ASIC (application specific integrated circuit).

[0111] Computers suitable for the execution of a computer program can include, by way of example, general or special purpose microprocessors or both, or any other kind of central processing unit. Generally, a central processing unit will receive instructions and data from a read-only memory or a random access memory or both. A computer generally includes a central processing unit for performing or executing instructions and one or more memory devices for storing instructions and data. Generally, a computer will also include, or be operatively coupled to receive data from or transfer data to, or both, one or more mass storage devices for storing data, e.g., magnetic, magneto optical disks, or optical disks. However, a computer need not have such devices. Moreover, a computer can be embedded in another device, e.g., a mobile telephone, a personal digital assistant (PDA), a mobile audio or video player, a game console, a Global Positioning System (GPS) receiver, or a portable storage device (e.g., a universal serial bus (USB) flash drive), to name just a few.

[0112] Computer readable media suitable for storing computer program instructions and data include all forms of nonvolatile memory, media and memory devices, including by way of example semiconductor memory devices, e.g., EPROM, EEPROM, and flash memory devices; magnetic disks, e.g., internal hard disks or removable disks; magneto optical disks; and CD-ROM and DVD-ROM disks. The processor and the memory can be supplemented by, or incorporated in, special purpose logic circuitry.

[0113] To provide for interaction with a user, embodiments of the subject matter described in this specification can be implemented on a computer having a display device, e.g., a CRT (cathode ray tube) or LCD (liquid crystal display) monitor, for displaying information to the user and a keyboard and a pointing device, e.g., a mouse or a trackball, by which the user can provide input to the computer. Other kinds of devices can be used to provide for interaction with a user as well; for example, feedback provided to the user can be any form of sensory feedback, e.g., visual feedback, auditory feedback, or tactile feedback; and input from the user can be received in any form, including acoustic, speech, or tactile input. In addition, a computer can interact with a user by sending documents to and receiving documents from a device that is used by the user; for example, by sending web pages to a web browser on a user's user device in response to requests received from the web browser.

[0114] Embodiments of the subject matter described in this specification can be implemented in a computing system that includes a back end component, e.g., as a data server, or that includes a middleware component, e.g., an application server, or that includes a front end component, e.g., a client computer having a graphical user interface or a Web browser through which a user can interact with an implementation of the subject matter described in this specification, or any combination of one or more such back end, middleware, or front end components. The components of the system can be interconnected by any form or medium of digital data communication, e.g., a communication network. Examples of communication networks include a local area network ("LAN") and a wide area network ("WAN"), e.g., the Internet.

[0115] The computing system can include clients and servers. A client and server are generally

remote from each other and typically interact through a communication network. The relationship of client and server arises by virtue of computer programs running on the respective computers and having a client-server relationship to each other.

[0116] While this specification contains many specific implementation details, these should not be construed as limitations on the scope of what may be claimed, but rather as descriptions of features that may be specific to particular embodiments. Certain features that are described in this specification in the context of separate embodiments can also be implemented in combination in a single embodiment. Conversely, various features that are described in the context of a single embodiment can also be implemented in multiple embodiments separately or in any suitable sub-combination. Moreover, although features may be described above as acting in certain combinations and even initially claimed as such, one or more features from a claimed combination can in some cases be excised from the combination, and the claimed combination may be directed to a sub-combination or variation of a sub-combination.

[0117] Similarly, while operations are depicted in the drawings in a particular order, this should not be understood as requiring that such operations be performed in the particular order shown or in sequential order, or that all illustrated operations be performed, to achieve desirable results. In certain circumstances, multitasking and parallel processing may be advantageous. Moreover, the separation of various system components in the embodiments described above should not be understood as requiring such separation in all embodiments, and it should be understood that the described program components and systems can generally be integrated together in a single software product or packaged into multiple software products.

[0118] Particular embodiments of the subject matter have been described. Other embodiments are within the scope of the following claims. For example, the actions recited in the claims can be performed in a different order and still achieve desirable results. As one example, the processes depicted in the accompanying figures do not necessarily require the particular order shown, or sequential order, to achieve desirable results. In certain implementations, multitasking and parallel processing may be advantageous. Other steps or stages may be provided, or steps or stages may be eliminated, from the described processes. Accordingly, other implementations are within the scope of the following claims.

### Terminology

[0119] The phraseology and terminology used herein is for the purpose of description and should not be regarded as limiting.

[0120] The term “approximately”, the phrase “approximately equal to”, and other similar

[0121] phrases, as used in the specification and the claims (e.g., “X has a value of approximately Y” or “X is approximately equal to Y”), should be understood to mean that one value (X) is within a predetermined range of another value (Y). The predetermined range may be plus or minus 20%, 10%, 5%, 3%, 1%, 0.1%, or less than 0.1%, unless otherwise indicated.

[0122] The indefinite articles “a” and “an,” as used in the specification and in the claims, unless clearly indicated to the contrary, should be understood to mean “at least one.” The phrase “and/or,” as used in the specification and in the claims, should be understood to mean “either or both” of the elements so conjoined, i.e., elements that are conjunctively present in some cases and disjunctively present in other cases. Multiple elements listed with “and/or” should be construed in the same fashion, i.e., “one or more” of the elements so conjoined. Other elements may optionally be present other than the elements specifically identified by the “and/or” clause, whether related or unrelated to those elements specifically identified. Thus, as a non-limiting example, a reference to “A and/or B”, when used in conjunction with open-ended language such as “comprising” can refer, in one embodiment, to A only (optionally including elements other than B); in another embodiment, to B only (optionally including elements other than A); in yet another embodiment, to both A and B (optionally including other elements); etc.

[0123] As used in the specification and in the claims, “or” should be understood to have the same

meaning as “and/or” as defined above. For example, when separating items in a list, “or” or “and/or” shall be interpreted as being inclusive, i.e., the inclusion of at least one, but also including more than one, of a number or list of elements, and, optionally, additional unlisted items. Only terms clearly indicated to the contrary, such as “only one of” or “exactly one of,” or, when used in the claims, “consisting of,” will refer to the inclusion of exactly one element of a number or list of elements. In general, the term “or” as used shall only be interpreted as indicating exclusive alternatives (i.e. “one or the other but not both”) when preceded by terms of exclusivity, such as “either,” “one of,” “only one of,” or “exactly one of.” “Consisting essentially of,” when used in the claims, shall have its ordinary meaning as used in the field of patent law.

[0124] As used in the specification and in the claims, the phrase “at least one,” in reference to a list of one or more elements, should be understood to mean at least one element selected from any one or more of the elements in the list of elements, but not necessarily including at least one of each and every element specifically listed within the list of elements and not excluding any combinations of elements in the list of elements. This definition also allows that elements may optionally be present other than the elements specifically identified within the list of elements to which the phrase “at least one” refers, whether related or unrelated to those elements specifically identified. Thus, as a non-limiting example, “at least one of A and B” (or, equivalently, “at least one of A or B,” or, equivalently “at least one of A and/or B”) can refer, in one embodiment, to at least one, optionally including more than one, A, with no B present (and optionally including elements other than B); in another embodiment, to at least one, optionally including more than one, B, with no A present (and optionally including elements other than A); in yet another embodiment, to at least one, optionally including more than one, A, and at least one, optionally including more than one, B (and optionally including other elements); etc.

[0125] The use of “including,” “comprising,” “having,” “containing,” “involving,” and variations thereof, is meant to encompass the items listed thereafter and additional items.

[0126] Use of ordinal terms such as “first,” “second,” “third,” etc., in the claims to modify a claim element does not by itself connote any priority, precedence, or order of one claim element over another or the temporal order in which acts of a method are performed. Ordinal terms are used merely as labels to distinguish one claim element having a certain name from another element having a same name (but for use of the ordinal term), to distinguish the claim elements.

## Claims

1. A computer-implemented method comprising: receiving, from an affiliate of a plurality of affiliates of an entity, a response to each of one or more questions, wherein at least one question of the one or more questions is mapped to at least one risk vector of one or more risk vectors and at least one risk vector rating for the at least one risk vector of one or more risk vector ratings, and wherein the one or more risk vector ratings are derived from externally-observable information for IP address-based assets of the affiliate; for each question mapped to at least one risk vector rating: determining a risk score for the question based on a weighted combination of the at least one risk vector rating and a weight for the at least one risk vector rating; determining, based on a comparison of the risk score to a threshold, an indication of whether the question is indicative of a cybersecurity risk; and when the risk score is less than or equal to the threshold, assigning a flag to the question to indicate the question is indicative of a cybersecurity risk; and causing display of an assessment report configured to show an assessment of cybersecurity risk of the affiliate, wherein the assessment report comprises the one or more questions, the response to each of the one or more questions, the at least one risk vector rating for each question mapped to the at least one risk vector, and the flag displayed with each question that is assigned the flag.

2. The computer-implemented method of claim 1, wherein each risk vector rating is indicative of a state of the respective risk vector of the affiliate.

3. The computer-implemented method of claim 1, wherein each question is indicative of a cybersecurity risk of the affiliate.
4. The computer-implemented method of claim 1, wherein the one or more risk vectors comprise at least one of: an amount of capital investment by the affiliate; a measure of employee training for the affiliate; an amount of the affiliate's budget for security; a number of lost records and/or sensitivity of information in the lost records in a data breach of a computer system associated with the affiliate; a number and/or type of service of open ports of a computer network associated with the affiliate; a number and/or severity of botnet infection instances of a computer system associated with the affiliate; an evaluation of file sharing traffic originating from a computer network associated with the affiliate; a number of spam propagation instances originating from a computer network associated with the affiliate; a number of malware servers associated with the affiliate; a number of potentially exploited devices associated with the affiliate; and a number of hosts authorized to send emails on behalf of each domain associated with the affiliate.
5. The computer-implemented method of claim 1, wherein the one or more risk vector ratings are numerical.
6. The computer-implemented method of claim 1, wherein each of the risk vectors comprises a respective risk vector type of a plurality of risk vector types.
7. The computer-implemented method of claim 6, wherein the plurality of risk vector types comprise at least one of a data breaches type, an open ports type, a botnet infections type, a potentially exploited device type, a file sharing type, and an other type.
8. The computer-implemented method of claim 7, wherein each of the plurality of risk vector types corresponds to a respective one of a plurality of weights, the plurality of weights being numerical and further comprising the weight for the at least one risk vector rating.
9. The computer-implemented method of claim 1, wherein the risk score for each question is calculated by dividing a sum of a multiplication of each of the risk vector ratings mapped to the question and the weights of each of the risk vector ratings by a sum of the weights of each of the risk vector ratings.
10. The computer-implemented method of claim 1, wherein the cybersecurity criticality tier is a level of criticality of a relationship between the entity and the affiliate.
11. A system for accelerating cybersecurity assessments, the system comprising: one or more processors; and a memory coupled with the one or more processors wherein the one or more processors executes a plurality of modules stored in the memory and wherein the plurality of modules comprises: a questionnaire management module that when executed receives, from an affiliate of a plurality of affiliates of an entity, one or more questions, wherein at least one question of the one or more questions is mapped to at least one risk vector of one or more risk vectors and at least one risk vector rating for the at least one risk vector of one or more risk vector ratings, and wherein the one or more risk vector ratings are derived from externally-observable information for IP address-based assets of the affiliate; a risk vector rating module that when executed for each question mapped to at least one risk vector rating: determines a risk score for the question based on a weighted combination of the at least one risk vector rating and a weight for the at least one risk vector rating; determines, based on a comparison of the risk score to a threshold, an indication of whether the question is indicative of a cybersecurity risk; and when the risk score is less than or equal to the threshold, assigns a flag to the question to indicate the question is indicative of a cybersecurity risk, and an assessment report generation module that when executed generates and causes display of an assessment report including an assessment of cybersecurity risk of the affiliate, wherein the assessment report comprises the one or more questions, the response to each of the one or more questions, the at least one risk vector rating for each question mapped to the at least one risk vector, and the flag displayed with each question that is assigned the flag.
12. The system of claim 11, wherein each risk vector rating is indicative of a state of the respective risk vector of the affiliate.

**13.** The system of claim 11, wherein the cybersecurity criticality tier is a level of criticality of a relationship between the entity and the affiliate.

**14.** The system of claim 11, wherein the one or more risk vectors comprise at least one of: an amount of capital investment by the affiliate; a measure of employee training for the affiliate; an amount of the affiliate's budget for security; a number of lost records and/or sensitivity of information in the lost records in a data breach of a computer system associated with the affiliate; a number and/or type of service of open ports of a computer network associated with the affiliate; a number and/or severity of botnet infection instances of a computer system associated with the affiliate; an evaluation of file sharing traffic originating from a computer network associated with the affiliate; a number of spam propagation instances originating from a computer network associated with the affiliate; a number of malware servers associated with the affiliate; a number of potentially exploited devices associated with the affiliate; and a number of hosts authorized to send emails on behalf of each domain associated with the affiliate.

**15.** The system of claim 11, wherein the one or more risk vector ratings are numerical.

**16.** The system of claim 11, wherein each of the risk vectors comprises a respective risk vector type of a plurality of risk vector types.

**17.** The system of claim 16, wherein the plurality of risk vector types comprise at least one of a data breaches type, an open ports type, a botnet infections type, a potentially exploited device type, a file sharing type, and an other type.

**18.** The system of claim 17, wherein each of the plurality of risk vector types corresponds to a respective one of a plurality of weights, the plurality of weights being numerical and further comprising the weight for the at least one risk vector rating.

**19.** The system of claim 11, wherein the risk score for each question is calculated by dividing a sum of a multiplication of each of the risk vector ratings mapped to the question and the weights of each of the risk vector ratings by a sum of the weights of each of the risk vector ratings.

**20.** The system of claim 11, wherein each question is indicative of a cybersecurity risk of the affiliate.

---